Title Of the Project: Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to application connectivity without exposing internal networks.

College Name: Maharani arts & science womens college ,Dharapuram

College Code: BRU4K

Team ID: SWTID-2026-4631

Team Size: 5

Team Leader: KAVIMOZHI K

List Of Team Mates:

S. NO	NAME	COLLEGE NAME	E-MAIL ID
1.	KAVIMOZHI K	MAHARANI ARTS AND SCIENCE WOMENS COLLEGE	Kavimozhi2210@gmail.com
2.	KANIMOZHI R	MAHARANI ARTS AND SCIENCE WOMENS COLLEGE	Kanimozhi1283@gmail.com
3.	GUNAVATHI A	MAHARANI ARTS AND SCIENCE WOMENS COLLEGE	Gunavathisk99@gmail.com
4.	KAYALVIZHI S	MAHARANI ARTS AND SCIENCE WOMENS COLLEGE.	Kayalvizhi089@gmail.com

5.	**SUBASRI R**	MAHARANI ARTS AND SCIENCE WOMENS COLLEGE	r.subasri0623@gmail.com

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Project details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

• AI-Enhanced User Protection (AIUP)

AI-Enhanced User Protection (AIUP) is a next-generation security framework that leverages artificial intelligence and machine learning to verify user identities and protect online platforms from cyber threats. Unlike traditional security measures that rely on static credentials like passwords or even two-factor authentication (2FA), AIUP continuously analyzes user behavior to create a dynamic, evolving "trust score" for each individual.

AIUP is essential for modern online security because it addresses the limitations of perimeter-based defenses. As cyber threats become more sophisticated—with attackers using stolen credentials, phishing, and social engineering—relying solely on "what you know" (passwords) or "what you have" (tokens) is no longer sufficient. AIUP adds a third, continuous layer: "who you are" based on how you behave. This system helps organizations prevent account takeovers, reduce fraud, and ensure that the person interacting with a platform is genuinely who they claim to be, throughout their entire session.

Abstract:

The limitations of legacy VPN architectures in addressing modern security threats, particularly lateral movement and over-privileged network access, necessitate a paradigm shift towards Zero Trust principles. This project details the comprehensive design, deployment, and management of a Zero Trust Network Access (ZTNA) solution leveraging Zscaler Private Access (ZPA) within a large-scale institutional network. The project aims to replace broad network-level access with application-specific, identity-driven connectivity. By deploying Zscaler App Connectors within the data center and integrating the platform with existing Identity Providers (Azure AD) and endpoint security tools, the architecture ensures that all user-to-application connections are established through a cloud-native broker. This approach renders internal applications "invisible" to the internet, eliminating the attack surface. Furthermore, the project explores the integration of Zscaler with security ecosystems, including SIEM platforms (like QRadar) for centralized logging and MISP for consuming threat intelligence to enable adaptive access policies. The result is a robust, scalable security framework that enforces least-privilege access, provides comprehensive audit trails, and significantly enhances the institution's resilience

Use Case Scenarios:

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member working from home needs to access the university's ERP system to upload student grades. Using Zscaler Private Access (ZPA), they connect securely without being placed on the internal network. The system verifies their identity via Azure AD MFA and checks their device posture before granting access.

Output:

- User identity verified (Faculty_Group)
- Device posture compliant (AV active, OS up-to-date)
- Secure micro-tunnel established to ERP Application only
- Network remains completely invisible to the user

Scenario 2: External Researcher Accessing a Specific Database

An external research collaborator from another institution requires temporary access to a single research database hosted on VIT's servers. The administrator creates a time-limited, application-specific policy in Zscaler. The researcher accesses only the authorized database without any visibility into the rest of the VIT network.

Output:

- External user identity verified via temporary credentials
- Access policy enforced (Time-limited: 7 days, Application: Research-DB only)
- Database server remains hidden from internet scanners
- Session automatically terminates after policy expiry

Scenario 3: Student Access to Online Examination Portal

During final exams, thousands of students simultaneously access the internal online examination portal from various locations. Zscaler ZPA ensures that only authenticated students with compliant devices can reach the exam server. The system prevents DDoS attacks on the login page and blocks any attempts to access other internal resources.

Output:

- Mass user authentication handled via cloud scalability
- Each student connected only to the exam application

- Lateral movement to grade database or other servers blocked
- Exam server IP address remains concealed from the internet

Scenario 4: IT Administrator Performing Server Maintenance

An IT administrator needs to perform critical updates on an internal application server. Instead of connecting via VPN and gaining full network access, they use ZPA to connect directly to the specific server's management interface. The session is monitored in real-time, and any anomalous behavior (e.g., accessing unauthorized servers) is automatically terminated.

Output:

- Admin identity verified with MFA
- Direct micro-tunnel to Server-Management-Interface only
- All admin keystrokes and commands logged for audit
- Attempt to access another server automatically blocked

Scenario 5: Mergers and Acquisitions – Temporary Contractor Access

A contractor hired during a university system upgrade needs temporary access to a specific file server to migrate data. Using Zscaler ZPA, the contractor is granted application-specific access without being added to the university's Active Directory or given VPN credentials. The access is revoked automatically after the project timeline.

Output:

- Contractor identity verified via separate IdP integration
- Access granted to File-Server-Migration share only
- All file transfer activities logged in Zscaler and SIEM
- Access automatically revoked after 30-day project end date

Stage-1

Title Of the Project: -

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview: -

The project aims to develop an AI-driven identity verification system that enhances online security by analysing and verifying user identities based on their online behaviour patterns. This system uses advanced machine learning techniques to create a robust user profile, distinguishing between legitimate users and suspicious activities. It addresses the pressing issue of unauthorised access, fraudulent transactions, and cyber threats across various online platforms and services.

The primary objective is to enhance online security significantly by scrutinising and validating user identities through their online behaviour. The system employs advanced machine learning techniques such as deep learning, neural networks, and natural language processing to establish comprehensive behavioural profiles for each user, which adapt and evolve with the user's behaviour over time. Real-time anomaly detection is a key feature of the system, identifying deviations from established user behaviour profiles and responding promptly to mitigate potential security threats.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data.

The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations.

Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components in multiple geographic regions.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data.

The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations.

Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components in multiple geographic

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability Name	CWE - No
1	Improper Sanitization of File Paths	CWE- 284: Improper Access Control
2	Invalid Certificate	CWE-395: Improper Certificate Validation
3	Missing X-Frame-Options Header	CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames
4	X-Content-Type Options Header Missing	CWE -918: Server-Side Request Forgery (SSRF)
5	Drupal Ajax API shows JSONP not disabled by default	CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

6	Drupal Api Vulnerability	CWE-20: Improper Input Validation
7	Improper API Filtration	CWE-79: Improper Neutralisation of Input During Web Page Generation ('Cross-site Scripting')
8	Denial of Service	CWE -400: Uncontrolled Resource Consumption
9	TLS Version 1.0 Protocol Detection	CWE-327: Use of a Broken or Risky Cryptographic Algorithm
10	web.config File Information Disclosure	CWE-497: Exposure of Sensitive System Information to an Unauthorised Control Sphere

Main Website:

S.no	Vulnerability Name	CWE - No
1	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation
3	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1) Vulnerability Name: Improper Sanitization of File Paths

CWE- 284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Recommendation:

1. **Apply Security Updates**: The primary recommendation is to apply the security update provided by Drupal as soon as it becomes available. Security updates typically include fixes for known vulnerabilities like this one.

2. **Review Configuration**: After applying the update, review your Drupal site's configuration to ensure that private files remain protected as intended. Make any necessary adjustments to your site's file permissions or access controls.

3. **Regular Audits**: Conduct regular security audits and vulnerability assessments to identify and address potential security issues in your Drupal site.

4. **Access Control**: Implement strong access controls to ensure that only authorized users can access private files. Review and restrict file access permissions as needed.

5. **Data Minimization**: Minimize the amount of sensitive data stored on your Drupal site. Only store data that is necessary for your site's functionality.

2) Vulnerability Name: Invalid Certificate

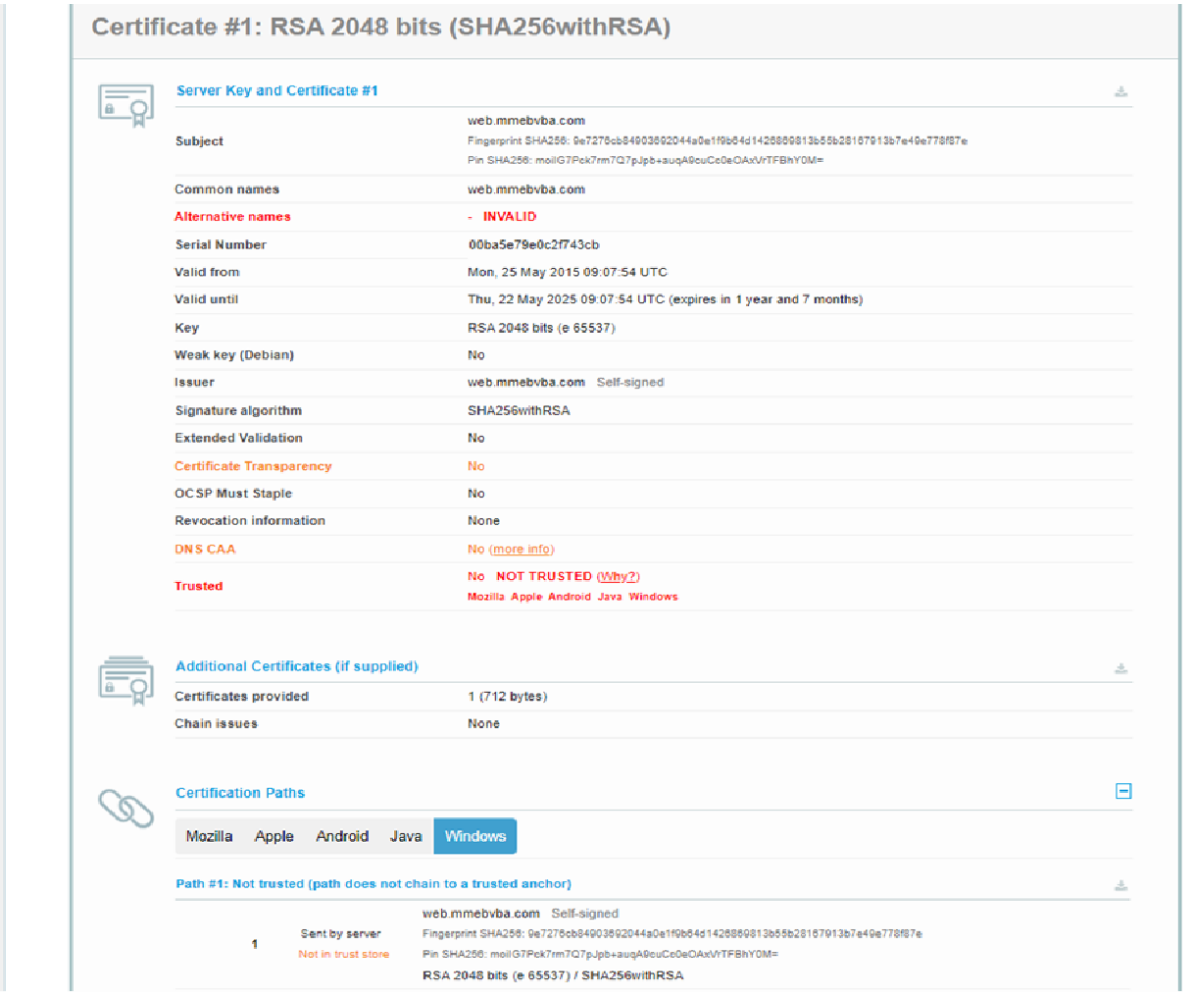
CWE-395: Improper Certificate Validation

OWASP Category: A07:2021 – Identification and Authentication Failures

Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact: Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Steps to Reproduce: https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+augA9cuCc0eOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+augA9cuCc0eOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

Recommendation:

1. **Use trusted certificate authorities:** Only trust digital certificates issued by well-known and trusted certificate authorities.

2. **Verify certificate chains:** Verify that the certificate presented by the remote party is valid and issued by a trusted certificate authority. Verify the entire certificate chain, including intermediate certificates.

3. **Check certificate revocation status:** Check the revocation status of the certificate presented by the remote party to ensure that it has not been revoked.

4. **Use certificate pinning:** Implement certificate pinning to ensure that the communication only occurs with the exact certificate or certificate authority specified.

5. **Keep software up to date:** Keep software and security protocols up to date, as new vulnerabilities and security patches are regularly released.

3) Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames

OWASP Category: A04:2021-Insecure Design

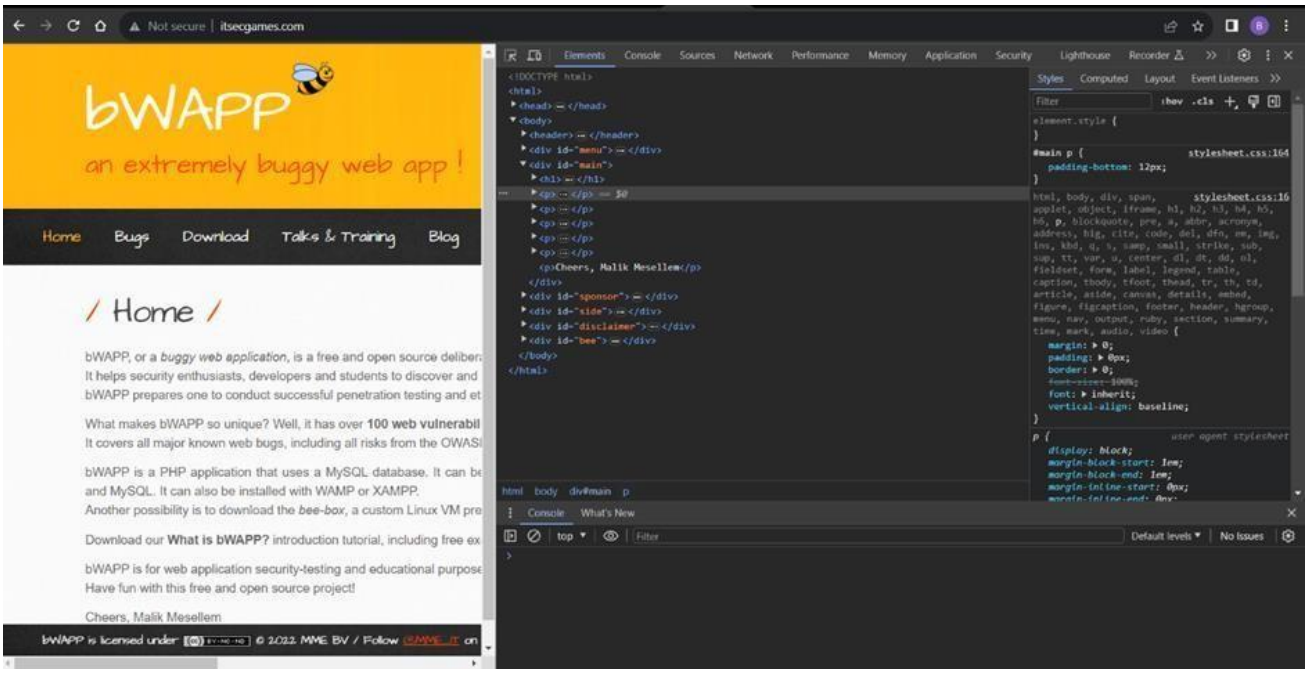
Description: A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the restrictions, users can be tricked into interacting with the application when they were not intending to.

Business Impact: This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses.

Vulnerability Path: http://www.itsecgames.com/

Steps to Reproduce:

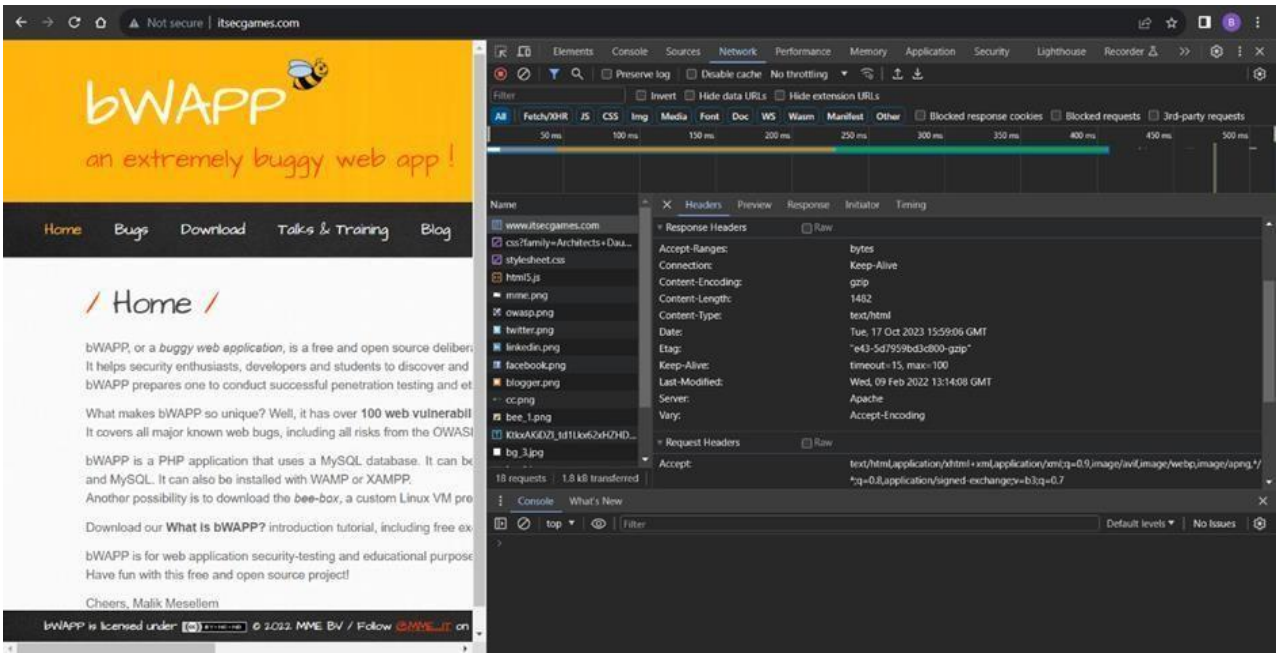
1. Open the practice website to inspect



2. Go to network and start capturing using F5 or Ctrl+R

3. Go to html document and see if x-frame-options present in response headers or not

4. If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.



Recommendation:

1. **Implement Proper UI Layer Access Controls:** Enforce access controls to restrict access to UI layers or frames based on user privileges.

2. **Use Session and Authentication Management:** Ensure robust session management and user authentication mechanisms to prevent unauthorized access.

3. **Implement Content Security Policies (CSP):** Use CSP headers to control where resources can be loaded from and mitigate against frame-based attacks.

4. **Keep Software and Libraries Updated:** Stay current with software updates and patches to address known security issues.

4) Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF)

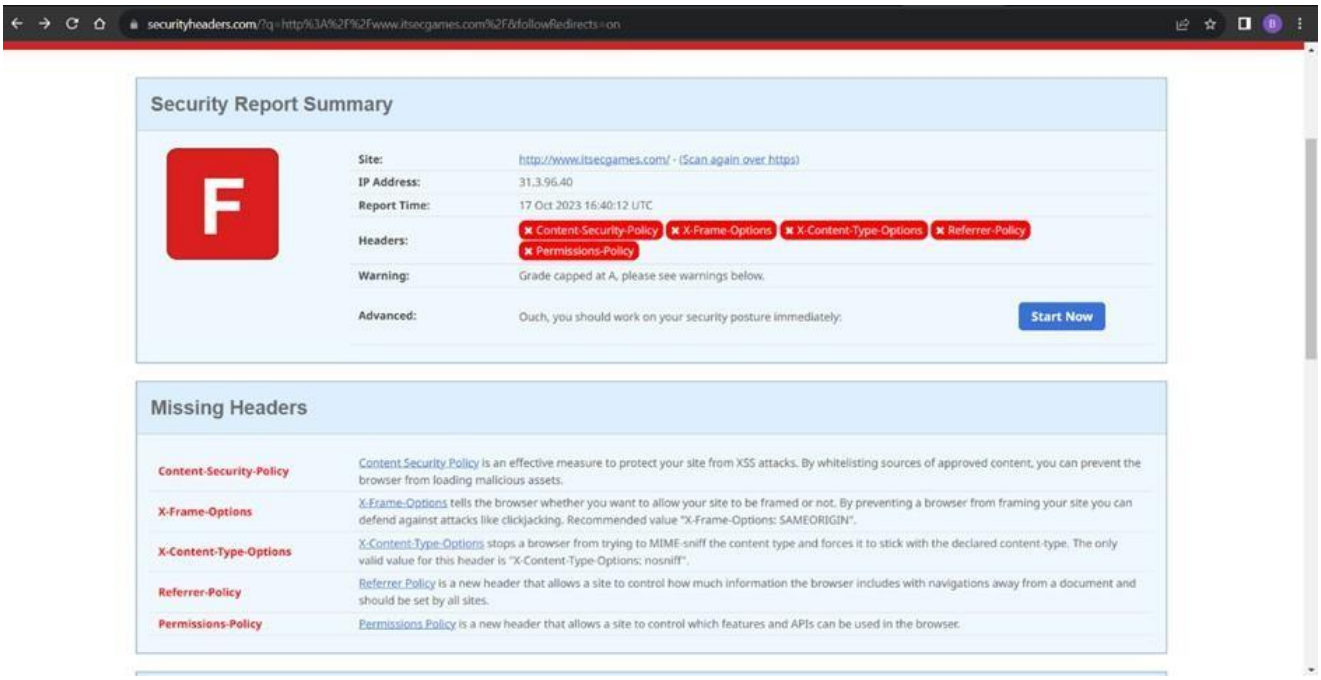
OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :
https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects=on

Steps to Reproduce:




```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    www.itsecgames.com
+ Target Port:        80
+ Start Time:         2023-10-17 09:03:40 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-
vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/proje
ct/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31
.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800,
 mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2023-10-17 09:29:14 (GMT5.5) (1534 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.

- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

5)Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components

Description: Vulnerable and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities.

Business Impact: The presence of vulnerable and outdated components in a web application poses significant security risks. Attackers can exploit these weaknesses to gain unauthorized access, inject malicious code, steal sensitive data, or disrupt the system's operation. The potential business impacts include compromised user data, damaged reputation, legal consequences, and financial losses due to breach recovery and remediation efforts.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13666	4.3 Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Recommendation:

1. **Regular Updates:** Keep all components, libraries, and dependencies up to date by applying security patches and upgrades.

2. **Vulnerability Scanning:** Conduct periodic vulnerability assessments to identify and address potential issues.

3. **Dependency Management:** Implement a strategy for managing third-party dependencies, including continuous monitoring of their security status.

4. **Security Testing:** Perform regular security testing, including penetration testing and code review, to identify and remediate vulnerabilities.

5. **Change Control:** Maintain a change management process to assess the impact of new components and ensure they don't introduce new vulnerabilities.

6) Vulnerability Name: Drupal Api Vulnerability

CWE-20: Improper Input Validation

OWASP Category: A03:2021 – Injection

Description: The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Business Impact: The impact of a successful SQL injection attack can be devastating for businesses. It can result in unauthorized access to sensitive information, data theft, financial losses, damage to reputation, and legal consequences. Depending on the nature of the application and data involved, SQL injection can lead to compliance violations, customer trust erosion, and operational disruption.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2022-25271	4.3 Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Recommendation:

1. **Input Validation:** Implement rigorous input validation on all user inputs and ensure that only safe, sanitized data is passed to the database.

2. **Parameterized Queries:** Use parameterized queries or prepared statements to separate SQL code from user input, preventing malicious injections.

3. **Escaping User Input:** If parameterized queries are not feasible, escape user input before incorporating it into SQL queries to neutralize special characters.

4. **Least Privilege Principle:** Limit the permissions and access rights of database accounts to the minimum required for specific tasks to minimize the potential damage of an attack.

5. **Web Application Firewalls (WAF):** Employ WAFs to filter and block malicious SQL injection attempts.

6. **Regular Security Testing:** Conduct regular security assessments, including penetration testing, to identify and address vulnerabilities.

7) **Vulnerability Name: Improper API Filtration**

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-site Scripting (XSS)

Description: The product does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users.

Business Impact: If exploited, this vulnerability allows attackers to inject malicious scripts into web pages, which can be viewed by other users. The potential business impacts include data theft, unauthorized access, compromised user accounts, damaged reputation, and financial losses. Attackers can use XSS to steal sensitive information, such as user credentials, personal data, or financial details, leading to regulatory compliance violations and legal liabilities. Additionally, defacement or manipulation of website content can erode customer trust and result in lost revenue.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40
Steps to Reproduce:

CVE-2020-13672	2.6 Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

Recommendation:

1. **Update and Patch:** Ensure that Drupal and all related modules and components are up to date with the latest security patches to mitigate known vulnerabilities.

2. **Input Validation:** Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.

3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.

4. **Secure Coding Practices:** Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.

5. **Security Scanning:** Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

8) Vulnerability Name: Denial of Service

CWE -400: Uncontrolled Resource Consumption

OWASP Category:

Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.

Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for paavan:
┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault  sudo nmap --top-ports 65536 31.3.96.40

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# msfconsole
```

```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40

[*] SYN flooding 31.3.96.40:80 ...
```

Recommendation: Employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilise load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up-to-date with the latest security patches to address known vulnerabilities that attackers may exploit.

9) Vulnerability Name: TLS Version 1.0 Protocol Detection

CWE-327: Use of a Broken or Risky Cryptographic Algorithm

OWASP Category: A02:2021-Cryptographic Failures

Description: The product uses a broken or risky cryptographic algorithm or protocol.

Business Impact: TLS 1.0 is an outdated and vulnerable encryption protocol, and its use can expose sensitive data to potential security threats. This not only jeopardizes the integrity of customer information and payment details but also tarnishes the company's reputation. The business may face legal consequences, loss of customer trust, and decreased revenue as security-conscious users avoid the site due to its security vulnerabilities. Immediate action is necessary to upgrade to a more secure TLS version to safeguard data, ensure compliance, and maintain customer confidence.

Steps to Reproduce:

1. Open a terminal or command prompt
2. Type the Command: openssl s_client -connect 31.3.96.40:443 -tls1
3. The connection is successfully means the server supports TLS 1.0

thanmaye08@THANMAYE: ~

File Actions Edit View Help

```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ openssl s_client -connect 31.3.96.40:443 -tls1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = web.mmebvba.com
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = web.mmebvba.com
verify return:1
---
Certificate chain
 0 s:CN = web.mmebvba.com
   i:CN = web.mmebvba.com
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIICxDCCAaygAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV
BAMMD3dlYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTRaFw0yNTA1MjIwOTA3
NTRaMBoxGDAWBgNVBAMMD3dlYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB
BQADggEPADCCAQoCggEBAK/hFlEmVRyv2fbXel6oUukbiGdpX0Xps5sqis2OxF9Y
/YXJcxaPoI/fUyfSdJ6prr2/YoEcUUfZaUIJWbsSz/qzklja0M+GMAVzL+wqAi+V
HjgujqsgeEQgxgTiNoQu9Zld5NY7Ac9qQRKbLBLRubQV/9+Dud0Isx3z1gAsJda6
bi3JuL0a27EMztRssKeQClJhWLAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0
Jr+GM175u2YLvXba+UZ2cWMOp5IZ359OHtkf0uuKSzUCAwEAAaMNMAswCQYDVR0T
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHg1qFsUlDarYKIrjuUxfeI2bE1fLd
VGIYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfkClVr3ayzS5KAMhvnZzga1B0+q
NYfX2y61SMnS4w9p8PT3iqZdF/RYwu658BXjpJWojwoA8Hu1mhwT0DdSSEofBnIq
azNm62lQsxdTlU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv
dJqxsYSZ3toPEuqlOryWis0E8pfo3Hauzz6fBGijLcEnMoFp7oCZNz0Xh9Q93aOs
5c9hNmHtQcu3vMrYUYArpj+a/euAEI2HaGJZf5g75mf4gAI/2B7iyg==
-----END CERTIFICATE-----
subject=CN = web.mmebvba.com
issuer=CN = web.mmebvba.com
---
No client certificate CA names sent
Peer signing digest: MD5-SHA1
Peer signature type: RSA
Server Temp Key: ECDH, prime256v1, 256 bits
---
SSL handshake has read 1404 bytes and written 274 bytes
Verification error: self-signed certificate
---
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
```

```
No ALPN negotiated
SSL-Session:
    Protocol  : TLSv1
    Cipher    : ECDHE-RSA-AES256-SHA
    Session-ID: 88C081DC5A60B2165E5ECF1174DFFA77732428624861E0BFAC934E3DE969B9E2
    Session-ID-ctx:
    Master-Key: 9A895BD34544E92181A631AB636C46EEC2788E9BFEE0DA5A6BDCA50E65C55250BA88EA
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
    0000 - 11 e0 e2 5c 44 79 52 91-7b 32 b1 10 22 9f 80 b5    ...\DyR.{2..".. ..
    0010 - 54 b6 b7 89 fe c7 7d 4a-18 bd 8c e3 e6 31 47 63   T.....}J.....1Gc
    0020 - 38 1b 52 ec 16 ac 18 b6-bd e1 76 e9 4b 41 24 ad   8.R.......v.KA$.
    0030 - e3 94 d2 60 65 35 8b e0-6e d2 76 db 1b e1 03 e7    ...`e5..n.v.....
    0040 - e7 76 cc f9 70 6a 42 91-94 42 e2 e8 29 d5 fd 38   .v..pjB..B..)..8
    0050 - 63 5f da 9f 09 af e0 d9-22 29 45 70 a7 a4 36 1f   c_......")Ep..6.
    0060 - 51 b1 cd d5 e7 b9 ef 9d-5d 20 99 ad 00 4d 21 df   Q.......] ...M!.
    0070 - 38 a6 c9 1b 76 29 87 d9-14 79 7a 73 33 f8 4c 8f   8...v)...yzs3.L.
    0080 - 12 ae 66 c1 ad c3 6c ba-68 63 11 6c b2 18 e0 89   ..f...l.hc.l....
    0090 - 97 54 50 d7 ee f5 e1 37-f4 b0 be 55 2f d1 25 63   .TP....7...U/.%c
    00a0 - c7 61 10 b3 ad 74 5a b7-07 fe e5 20 b1 da a1 a2   .a...tZ.... ....
    00b0 - be dd c8 45 a7 74 b7 eb-ee 9a 15 dc 1b bb 0b d9    ...E.t..........

    Start Time: 1697691531
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: no
---
4037A3514B7F0000:error:0A000126:SSL routines:ssl3_read_n:unexpected eof while reading:
```

Recommendation:

1. **Upgrade to a Secure TLS Version:** Transition to a more secure TLS version, such as TLS 1.2 or TLS 1.3. This will provide stronger encryption and improved security against modern threats.

2. **Regularly Update SSL/TLS Configuration:** Keep your SSL/TLS configuration up to date to ensure it aligns with the latest security best practices and vulnerabilities.

3. **Implement a Strong Cryptographic Suite:** Use strong cipher suites and secure configurations to further enhance security. Disable weak ciphers and outdated protocols.

4. **Compliance Checks:** Ensure that your website complies with relevant data protection regulations and industry standards (e.g., GDPR, PCI DSS) to avoid legal issues.

10) Vulnerability Name: **web.config File Information Disclosure**

CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere

OWASP Category: A3:2017-Sensitive Data Exposure

Description: An information disclosure vulnerability exists in the remote web server due to the disclosure of the web.config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.

Business Impact: It exposes sensitive configuration details, including database connection strings and encryption keys, to potential attackers. This could lead to unauthorized access, data breaches, and system compromise. The impact includes financial losses, damage to reputation, and legal liabilities as the organization's security and customer trust are compromised.

Steps to Reproduce:

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation:

- Implement proper access controls to restrict access to the web.config file.
- Prevent directory traversal and ensure the web.config file cannot be directly accessed through the web server.
- Encrypt sensitive data within the configuration file.
- Regularly review and update the web.config file, removing any unnecessary sensitive information.
- Ensure that the web.config file is properly secured and not accessible to unauthorized users.

Main Website: vtop.vit.ac.in

1) **Vulnerability Name: SL Medium Strength Cipher Suites Supported (SWEET32)**

CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

OWASP Category: Broken access control

Description: The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Business Impact: The vulnerability known as SWEET32 (Short for Sweet 32 Birthday Attack) relates to the continued use of legacy cryptographic cipher suites with 64-bit block sizes in TLS and SSL protocols. These suites are susceptible to birthday attacks, which exploit the probability of two blocks colliding after a certain number of transactions. If an organisation's systems are vulnerable to SWEET32, it means they're potentially at risk of having encrypted communications intercepted or manipulated. This could lead to unauthorised access, data theft, or even the injection of malicious code. As a result, businesses face a significant risk to the confidentiality and integrity of their sensitive information. Remediation involves updating systems to support more secure cipher suites with larger block sizes, which would effectively mitigate this vulnerability and enhance the overall security posture. Failure to address SWEET32 could leave an organisation exposed to increasingly sophisticated attacks and legal consequences due to potential data breaches.

Vulnerability Path : The Sweet32 vulnerability when detected with a vulnerability scanner will report it as a CVSS 7.5.

Steps to Reproduce:

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                      Code            KEX          Auth     Encryption             MAC
  ----------------------    ----------      ---          ----     ---------------------  ---
  EDH-RSA-DES-CBC3-SHA      0x00, 0x16      DH           RSA      3DES-CBC(168)          SHA1
  ECDHE-RSA-DES-CBC3-SHA    0xC0, 0x12      ECDH         RSA      3DES-CBC(168)          SHA1
  DES-CBC3-SHA              0x00, 0x0A      RSA          RSA      3DES-CBC(168)          SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	136.233.9.22

Plugin Details

Severity:	High
ID:	42873
Version:	1.21
Type:	remote
Family:	General
Published:	November 23, 2009
Modified:	February 3, 2021

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Risk Factor: Medium
CVSS v3.0 Base Score 7.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 24, 2016

Recommendation: organisations should take several proactive steps. Firstly, it is crucial to update and configure cryptographic libraries, web servers, and any network devices to disable support for cipher suites with 64-bit block sizes. This can be achieved by ensuring that only modern and secure cipher suites are enabled in the TLS/SSL configurations. Additionally, organizations should regularly monitor and assess their systems for any outdated or vulnerable protocols and promptly apply security patches and updates. Implementing strong, unique encryption keys and employing forward secrecy protocols can further bolster security. It's also recommended to utilize intrusion detection systems and perform regular security audits to identify and address any potential vulnerabilities promptly. Lastly, organizations should stay informed about emerging security threats and best practices in cryptographic protocols to proactively adapt their security measures. By taking these measures, businesses can significantly reduce the risk of falling victim to SWEET32 attacks and enhance the overall security of their digital infrastructure.

2) **Vulnerability Name:** **Cookie SERVERID created without secue flag**

CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A07-2017: Cross-site Scripting

Description: The vulnerability allows an attacker to inject malicious code into a WordPress website, which can then be executed by visitors to the website.

To exploit this vulnerability, an attacker would simply need to trick a user into clicking on a malicious link or opening a malicious attachment. Once the user clicks on the link or opens the attachment, the attacker's code would be executed, giving the attacker control over the user's account and potentially the entire WordPress website.

Business Impact: The business consequences of XSS can be severe, ranging from reputational damage due to compromised customer trust, to legal repercussions in cases of data breaches. Moreover, it can lead to financial losses through fraud or the cost of remediation efforts. Beyond the immediate impacts, long-term harm may occur if customers abandon the platform due to security concerns. To mitigate CWE-79, businesses must implement rigorous input validation and output encoding practices, as well as stay vigilant for emerging threats in web application security. Failure to address XSS vulnerabilities could result in significant harm to both the business's reputation and its bottom line.

Vulnerability Path: https://securityheaders.com/

q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

1. **Update and Patch:** Ensure that Drupal and all related modules and components are up to date with the latest security patches to mitigate known vulnerabilities.
2. **Input Validation:** Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.
3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.
4. **Secure Coding Practices:** Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.
5. **Security Scanning:** Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

3) **Vulnerability Name: X-Content-Type Options Header Missing**

CWE-918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The absence of the "X-Content-Type-Options" header poses a notable security risk for web applications. This header is a crucial security feature that instructs the browser to interpret files with a MIME type as declared in the Content-Type header, rather than trying to guess the type. When this header is missing, the browser may attempt to infer the content type, leaving room for potential misinterpretation and security vulnerabilities like MIME-sniffing attacks. This could enable attackers to disguise malicious content, such as scripts or executable files, as benign content, leading to Cross-Site Scripting (XSS) or other types of attacks. Implementing the "X-Content-Type-Options" header with the value "nosniff" is a fundamental security measure that helps prevent these risks. It ensures that browsers strictly adhere to the declared content type, enhancing the overall security posture of the web application and safeguarding against potential exploitation stemming from content misinterpretation.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :
https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.
- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

4) **Vulnerability Name: Denial of Service**

CWE - 400: Uncontrolled Resource Consumption

Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.

Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 443 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 18:27 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.044s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1 c
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Linux 5.1 (87%), Apple macOS 10.13 (High Sierra
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

```
┌──(root㉿kali)-[/home/paavan]
└─# msfconsole

       =[ metasploit v6.3.27-dev                          ]
+ -- --=[ 2335 exploits - 1220 auxiliary - 413 post       ]
+ -- --=[ 1385 payloads - 46 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: Adapter names can be used for IP params
set LHOST eth0
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 136.233.9.22
RHOST => 136.233.9.22
msf6 auxiliary(dos/tcp/synflood) > set RPORT 443
RPORT => 443
msf6 auxiliary(dos/tcp/synflood) > exploit
[*] Running module against 136.233.9.22

[*] SYN flooding 136.233.9.22:443...
^C[-] Stopping running against current target...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(dos/tcp/synflood) >
```

Recommendation: employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilise load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up-to-date with the latest security patches to address known vulnerabilities that attackers may exploit.

5) **Vulnerability Name: OS Identification**

CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

OWASP Category: A02:2021-Cryptographic Failures

Description: Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact: If sensitive information is improperly handled or inadequately protected, it can lead to financial losses, regulatory penalties, and damage to reputation. Customers may lose trust in the organization's ability to safeguard their data, potentially resulting in a loss of business and market share. Legal consequences and compliance issues may arise, leading to additional costs. Moreover, intellectual property theft or exposure can compromise a company's competitive edge. Remediation efforts, including implementing stronger security measures and compensating affected parties, can also entail substantial expenses. Overall, CWE-200 highlights the critical importance of robust data protection measures to safeguard an organization's financial health, reputation, and long-term viability.

Steps to Reproduce: use nmap -O TARGET to enable os detection

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 19:13 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.043s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:apple:mac_os_x:10.13 cpe:/o:linux:linux_kernel:5.1
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Apple macOS 10.13 (High Sierra) (Darwin 17.0.0) (86%), Linux 5.1 (86%), Linux 3.2 - 4.9 (86%), Linux 3.18 (
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
```

Recommendation: implementing robust encryption protocols for data both in transit and at rest, coupled with stringent access controls and strong authentication measures. Regular vulnerability assessments and penetration testing should be conducted to identify and rectify potential weak points. Educating employees through comprehensive security awareness training is vital, emphasising proper data handling practices and recognition of potential threats. Employing data masking techniques for non-production environments and utilising advanced Data Loss Prevention (DLP) solutions can further fortify defences. Additionally, maintaining compliance with relevant data protection laws and regulations, as well as establishing a well-defined incident response plan, are crucial components of a comprehensive strategy to safeguard against sensitive information exposure.

This is stage 1 in the context of web application testing and security
we take help from
OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most critical web application security risks. Understanding these risks is essential for ensuring the security of web applications.

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) **Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection**

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non-compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8) Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network

management, optimization, and ensures that the right security measures are in place for each device type.

9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS**.**

Business Impact: -Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

10) Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

Stage-3

Report: -

Title: - Implementing Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

• Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is an IT security framework that provides secure remote access to an organization's internal applications and data based on clearly defined access control policies. Unlike traditional Virtual Private Networks (VPNs), which grant users broad access to the entire network, ZTNA operates on a "never trust, always verify" principle. It grants users access only to the specific applications they need, and only after their identity and device have been verified.

ZTNA is a critical component of modern security architecture. It helps organizations move away from the concept of a trusted internal network and an untrusted external network (the "castle-and-moat" model). By hiding the internal network from the internet and establishing one-to-one, encrypted connections between users and applications, ZTNA drastically reduces the attack surface and stops common threats like lateral movement by attackers.

• The ZTNA Access Cycle

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy for every access request. It typically consists of the following steps:

1. User Request: A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an internal code

repository).

2. Identity and Device Verification: Before any connection is established, the ZTNA solution verifies who the user is (via multi-factor authentication, or MFA) and checks the security posture of their device. This includes ensuring the device has up-to-date antivirus, a healthy firewall, and is not compromised.
3. Policy Enforcement: The ZTNA solution checks the access policy. Does this specific user, with this specific device, have permission to access the requested application at this specific time?
4. Establish Secure Connection: If the policy allows access, the ZTNA solution creates a highly secure, encrypted micro-tunnel between the user's device and the target application. Crucially, the user never gains access to the underlying network, only to the application itself.
5. Continuous Monitoring: The ZTNA solution continues to monitor the connection for anomalies. If the user's behavior becomes suspicious or their device posture changes, the connection can be terminated in real-time.
6. Logging and Analytics: All access attempts, successful and failed, are logged and analyzed. This data is used for auditing, threat hunting, and refining access policies.

• Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-native security platform that delivers its services entirely from the cloud, eliminating the need for on-premises hardware like VPN concentrators. For ZTNA, Zscaler offers Zscaler Private Access (ZPA) . ZPA is a service that provides seamless, identity-based access to private applications without ever placing users on the network.

Zscaler ZPA operates on a simple principle: the application is "inside" the Zscaler cloud, and the user connects to it there. It collects data from a variety of sources, including:

1. Identity Providers (IdP): Such as Azure AD, Okra, or Ping Identity, to verify user identities.
2. Device Posture Partners: Such as CrowdStrike, Tanium, or Microsoft Defender for Endpoint, to check the health of the endpoint.
3. Business Applications: The internal web apps, file servers, and legacy applications hosted in data centers or public clouds (e.g., AWS, Azure).
4. Zscaler App Connectors: Lightweight software components deployed in the data center or cloud that initiate outbound connections to the Zscaler cloud, making internal servers invisible to the internet.

Zscaler then enforces policies based on this data, including:

1. Identity-Based Access: Policies are built around user and group identities, not IP addresses.
2. Application Segmentation: Users are granted access to specific applications, not entire subnets.
3. Least Privilege Access: Ensures users have the minimum level of access required to perform their jobs.

• The Zscaler ZTNA Cycle

The Zscaler ZTNA cycle is the practical application of the ZTNA principles using the Zscaler cloud. The cycle typically consists of the following steps:

1. User Login and Authentication: A user attempts to access an internal application. They are redirected to their organization's Identity Provider (IdP) for authentication and MFA.
2. Device Posture Check (Integration): Zscaler checks with integrated endpoint protection tools to ensure the device is compliant with security policies.
3. Policy Lookup and Decision: The Zscaler cloud evaluates the request against the defined access policies. It verifies that the user, device, and context (time, location) are authorized for that specific application.
4. Establishing the Micro-tunnel: Once authorized, the Zscaler cloud instructs the user's Zscaler Client Connector and the appropriate Zscaler App Connector in the data center to establish an encrypted connection. The user is now connected to the application.
5. Traffic Inspection (Optional): For sanctioned applications, Zscaler can optionally inspect the traffic for data loss prevention (DLP) or to detect malware.
6. Logging and Analytics: All activity is logged in the Zscaler cloud portal for reporting, threat hunting, and compliance.

• MISP (Malware Information Sharing Platform) Integration

While Zscaler is a primary access control tool, it can be enhanced by integrating with threat intelligence platforms like MISP.

1. Threat Intelligence Feed: MISP can aggregate and share threat intelligence about malicious domains, IPs, and URLs. This list of indicators of compromise (IOCs) can be fed into Zscaler's cloud.
2. Proactive Blocking: If a user, even one authorized by ZPA, attempts to access a known malicious site that has been flagged by the MISP feed, Zscaler Internet Access (ZIA) can block the request, preventing a potential infection.
3. Enhanced Visibility: Security teams can use MISP to cross-reference Zscaler logs. If a user's behavior is anomalous, the team can check MISP to see if the destination IP or domain is associated with a known threat actor or campaign.

• Your College Network Information

This infrastructure presents a large attack surface, especially with the need for remote learning and

administrative access. The network includes:

- Core routers and switches
- Distribution routers and switches
- Wireless access points
- Firewalls and Intrusion Detection Systems (IDS)
- Internal Application Servers: Hosting the student information system, library resources, research data repositories, and administrative portals.
- Legacy VPN Concentrator: Currently providing broad network-level access for faculty and staff working remotely.

The need for ZTNA arises from the limitations of the current VPN model:

- Over-permissioned Access: Once on the VPN, a faculty member's compromised laptop could potentially scan and attack the entire internal network (lateral movement).
- Hidden Applications: Some research applications need to be accessed by external collaborators without granting them full network access.
- User Experience: The legacy VPN can be slow and cumbersome, often requiring users to route all their internet traffic through the university.

• How you think you deploy ZTNA using Zscaler in your college

To deploy Zscaler ZTNA (ZPA) in your college, you would start by identifying the specific applications that need to be secured and the user groups that need access to them. This is a shift from securing the network to securing access to applications.

The plan would need to include the following:

1. Application Discovery: Catalog all internal applications (e.g., ERP, library system, research servers, file shares) and identify which ones are currently exposed via the VPN.
2. User Segmentation: Define user groups (e.g., Students, Faculty - Research, Faculty - Admin, IT Staff, External Collaborators) and the specific applications each group needs.
3. Deploying Zscaler App Connectors: Install lightweight App Connector VMs in the university's data center. These connectors will establish outbound connections to the Zscaler cloud, making the application servers invisible to the public internet.
4. Integrating Identity Provider: Connect Zscaler to the university's existing Identity Provider (e.g., Microsoft Azure AD) to leverage current usernames, passwords, and MFA policies.
5. Configuring Access Policies: Create granular policies in the Zscaler admin portal. For example: "The 'Faculty' group can access the 'ERP Application' from any device that has antivirus enabled, after MFA."

6. Deploying Zscaler Client Connector: Students, faculty, and staff will install the Zscaler Client Connector on their laptops and mobile devices. This small client intelligently routes traffic for private applications through ZPA and public traffic through ZIA.

• **Threat Intelligence**

In the context of Zscaler and ZTNA, threat intelligence is used to understand who is trying to access what, and from where. It helps move beyond simple identity checks to a more contextual understanding of risk.

Sources include:

1. Zscaler Cloud Logs: Internal logs provide real-time data on who is accessing which applications, from which locations, and on what devices.
2. External Threat Feeds (MISP): Information about new malware campaigns, phishing kits, or command-and-control servers being used by attackers.
3. Identity Provider Logs: Anomalies in login attempts, such as a user logging in from two geographically impossible locations in a short time, can signal a compromised account.

This intelligence is used for:

1. Adaptive Access Control: If threat intelligence suggests a user's location is high-risk, Zscaler can step-up authentication requirements or block access entirely.
2. Hunting for Compromised Accounts: Analysts can use Zscaler logs to see if a user is suddenly accessing applications they never have before, which could be a sign of credential theft.
3. Blocking Malicious Communication: Threat intelligence feeds can be used by Zscaler Internet Access (ZIA) to block outbound connections to known malicious sites, even if they originate from a user inside the university.

• **Incident Response (Adapted for ZTNA)**

Incident response in a ZTNA model is faster and more targeted because the environment is inherently more controlled.

1. Detection: The SOC team detects an anomaly. For example, a faculty account is downloading an unusually high volume of data from a research server at 3 AM. Zscaler logs provide the exact details: the user, the device, the application, and the amount of data transferred.
2. Containment: The SOC team can instantly isolate the user. In the Zscaler portal, they can simply deactivate that user's access or block their specific device. Because there is no network-level access, this action immediately severs all connections to every application, preventing lateral movement.
3. Eradication: The compromised device is taken offline for malware scanning and cleaning by the IT helpdesk.
4. Recovery: Once the device is clean and the user's password is reset, the Zscaler policy is re-enabled, granting the user access again.
5. Post-incident review: The security team analyzes the logs to understand how the account was compromised (e.g., a phishing email) and updates Zscaler policies, perhaps by adding a block for similar malicious domains or tightening access rules for that specific research application.

Benefits of this incident response approach:

1. Near-Instant Containment: Actions take seconds in a cloud dashboard, not minutes or hours configuring firewall rules.
2. No Lateral Movement: The attacker is contained to the single compromised application, protecting the rest of the university's network.

3. Granular Forensics: Zscaler provides a detailed audit trail of every connection, making investigations faster and more accurate.
4. Compliance: This model helps demonstrate compliance with data protection regulations by proving that access to sensitive student or research data is tightly controlled and audited.

• **Understanding about the tool (Zscaler ZPA)**

Zscaler Private Access (ZPA) is a cloud service that embodies the ZTNA principle of "connect a user to an app, not the network." Here are the key things to understand:

1. It is "Application-Centric," Not "Network-Centric": You define policies based on applications (e.g., "SAP Server 01"), not network constructs like IP subnets. This aligns security with how businesses actually operate.
2. It Hides the Network: ZPA uses App Connectors inside your data center that only make *outbound* connections to the Zscaler cloud. Your internal servers never need to open inbound firewall ports, making them invisible to port scanners and attackers on the internet.
3. It uses a "Dark Cloud" Approach: To an external scanner, the organization's applications simply don't exist. They only become visible to authorized users after a multi-step verification process.
4. It Provides a Superior User Experience: Users don't have to mess with clunky VPN clients. The Zscaler Client Connector works silently in the background. For web apps, access can even be agentless, requiring only a modern browser.
5. It is Inherently Scalable: Because it's a cloud service, ZPA scales instantly to handle thousands of concurrent users, unlike a legacy VPN appliance that needs to be manually upgraded.

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 introduced the pivotal concept of Zero Trust Network Access (ZTNA) and its implementation using Zscaler Private Access (ZPA). It demonstrated a paradigm shift from traditional VPN-based network access to secure, identity-based user-to-application connectivity. The solution showcased the power of hiding internal applications from the internet, enforcing granular access policies, and eliminating lateral movement. This underscores the need for modern, proactive cybersecurity strategies in an era of remote work and cloud adoption.

Considering the future scope, **Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. **AI-Driven Zero Trust (AI-ZTA):** Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.
2. **Integration with Edge Computing and IoT:** As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.
3. **Identity-Centric Everything:** The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including **continuous behavioral biometrics** (keystroke dynamics, gait analysis) and **decentralized identity** solutions using blockchain, ensuring that the user behind the session is verified at all times.
4. **Convergence with SASE Architecture:** Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location.

5. **Zero Trust for Operational Technology (OT) and Critical Infrastructure:** Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical infrastructure. Future scope includes air-gapped Zero Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.
6. **Automated Threat Hunting and Response:** Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, isolate affected systems, and even roll back malicious changes.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END